시계열 문맥을 반영한 행동 기반 이상 탐지: 다변량 마할라노비스 거리를 활용한 계정 탈취자 및 매크로 봇 식별 연구

부제: 정적 임계값 우회 공격에 대응하는 시간 구조 변수와 운동 역학 변수의 상보적 결합 검증

작성자: 최재영

작성일: 2026 년 10 월 23 일 (v2 최종 수정: 2026 년 10 월 26 일)

초록 (Abstract)

본 연구는 평균 입력 속도와 산포도를 정상 사용자와 동일하게 위장한 지능형 매크로 봇 및 계정 탈취자의 비정상 접근을 단일 정적 임계값만으로는 식별할 수 없다는 문제의식에서 출발하였다. 이를 해결하기 위해 키보드 및 마우스 활동 로그에서 추출한 시계열적 리듬 지표들이 비정상 접근을 유의미하게 분리해낼 수 있는지 검증하였다. 실험은 정상 사용자(User_A), 계정 탈취 타인(Impostor_B), 고정 주기 단순 봇(Bot_Fixed), 균등분포 난수 지연 지능형 봇(Bot_Random)의 4 개 행동 주체 조건에 대해 동일 과업(30 타 타이핑 및 5 개 좌표 클릭)을 각 15 회씩 총 60 회 반복 수행하고, 7 종의 시계열 파생변수와 다변량 마할라노비스 거리를 측정하는 방식으로 진행되었다. 원자료 분석 결과, 평균 타건 간격이나 누름 시간 표준편차 같은 단일 지표는 조건 간 분포가 크게 겹쳤으며, 1 차 자기상관계수 역시 인간 그룹 간(User_A 와 Impostor_B)에서 상당 부분 중첩되어 단독 변수만으로는 완벽한 분리가 불가능했다. 그러나 '시간 구조 변수(자기상관성·샤논 엔트로피)'와 '운동 역학 변수(타건 지연·마우스 가속도 표준편차)'를 Ledoit-Wolf 축소 공분산 기반 다변량 마할라노비스 거리로 결합했을 때, 정상 사용자는 0.34~2.52(평균 0.97)에 수렴한 반면 타인(6.10~10.18), 지능형 난수 봇(10.74~11.86), 단순 봇(13.00~13.03)은 최소 3.58 이상의 안전 마진을 두고 60 회 전 시행에서 겹침 없이 분리되었다. 본 연구는 이 결과를 실전 행동 기반 계정 보호 위젯으로 구현해, 등록 기반 '본인 대 타인' 식별(계정 탈취 방어, 핵심 보안 기여)을 주 기능으로, 등록 없는 '사람 대 기계' 판별(매크로 탐지, 부정 사용 방지 성격)을 부가 기능으로 분리 적용하였다. 다만 원자료 재생성 과정에서 원 논문이 기술한 거리 산출 방법으로는 최초 보고 수치(마할라노비스 거리 1.08~2.94 등, 안전 마진 4.70)가 재현되지 않음을 확인하였고(연구자 확인 후 Ledoit-Wolf 공분산을 정식 방법으로 채택), 이 과정과 근거는 P0_리포트.md 에 전량 공개하였다. 본 연구는 행동 기반 보안 탐지의 핵심이 개별 변수의 단독 임계값이 아닌 상보적 시계열 변수들의 다변량 결합에 있음을 실증하였다.

---

1. 서론 (Introduction)

1.1 연구 배경 및 문제의식

현대 정보 보안 환경에서 초기 로그인 단계의 패스워드 인증만으로는 세션 탈취(Session Hijacking)나 정교하게 설계된 자동화 매크로 봇(Bot)의 악의적 활동을 차단하기 어렵다. 특히 최근의 지능형 봇은 초당 요청 횟수나 평균 입력 지연 시간 같은 정적 임계값(Static Threshold) 탐지를 우회하기 위해 인간과 유사한 평균 속도에 난수 지연(Random Delay)을 주입하는 방식을 사용한다. 본 연구는 단일 이벤트의 정적 기준이 가지는 이러한 한계를

극복하기 위해, 이벤트가 발생하는 '시계열적 흐름과 운동 역학적 리듬'에 주목하였다.

1.2 핵심 연구 가설 및 기각 기준

- **초기 연구 가설:** 사용자의 입력 및 활동 로그에서 추출한 시계열적 리듬(타건 간격, 마우스 가속도, 이벤트 발생 간격의 자기상관성 및 엔트로피 등)의 다변량 분포는 개인 고유한 '행동 지문(Behavioral Fingerprint)'을 형성하므로, 단일 이벤트의 정적 기준만으로는 포착할 수 없는 계정 탈취자나 자동화 매크로 봇의 비정상 접근을 통계적으로 유의미하게 분리해낼 수 있다.
- **가설 기각 시 예상되는 데이터 결과:** 동일 사용자의 컨디션이나 작업 환경에 따른 행동 시계열 변수의 '개인 내 분산(Intra-user variance)'이 '사용자 간 분산(Inter-user variance)'보다 크거나 같게 나타나, 다변량 공간에서 정상 사용자와 침입자(또는 봇)의 데이터 분포가 서로 완전히 겹치며 유의미한 결정 경계가 형성되지 않을 것이다.

1.3 후보 주제 검토 및 본 주제 선정 근거

연구 기획 단계에서 직접 데이터를 수집하고 검증할 수 있는 보안·데이터 융합 주제들을 검토하였으며, 최종적으로 실시간 행동 로그 시계열 분석을 채택하였다. 함께 검토했으나 후속 연구 과제로 보류한 세 가지 주제와 그 학술적 가치는 다음과 같다.

1. **보안 취약점 및 사이버 리스크의 정량화 (NVD CVE 및 GitHub API 결합 분석):** 생존 분석(취약점 발견부터 패치까지의 소요 시간 분석)이나 포아송·음이항 회귀(단위 기간당 취약점 발생 건수 모델링) 등 정통 통계학 기법을 보안 도메인에 깔끔하게 적용할 수 있고 오픈 API 가 잘 구축되어 있어 데이터 전처리와 모델링에 집중할 수 있다는 점에서 높은 가치를 지닌다. 다만 NVD·GitHub API 가 제공하는 값은 제 3 자가 이미 수집·정제해 둔 관찰 데이터라, 본 연구가 요구한 '직접 원천 데이터를 생성하고 검증'하는 조건을 충족하지 못해 보류하였다.
2. **개념 표류(Concept Drift) 조기 감지 및 재학습 주기 결정 (피싱 URL 시계열 수집):** 정적인 데이터셋에서의 일회성 정확도 평가를 넘어, 모델 배포 이후 시간에 따라 공격 패턴 분포가 변할 때 이를 통계적 검정(KS-test, PSI, Jensen-Shannon Divergence 등)으로 어떻게 조기 감지할지 다루어 실무 및 MLOps 관점에서 차별성이 매우 크다. 다만 배포 후 공격 패턴 변화를 통계적으로 감지하려면 과제 기간을 넘어서는 장기간의 피싱 URL 시계열 수집과 실제 운영 중인 배포 모델이 필요해, 정해진 제출 기한 안에서는 직접 검증이 어렵다고 판단해 보류하였다.
3. **차등 프라이버시(Differential Privacy)의 최적점 탐색 (노이즈 주입 실험):** 라플라스나 가우시안 분포에서 추출한 통계적 노이즈(ε)가 표본평균·분산·회귀계수 추정량에 미치는 영향을 수리통계학적으로 명확히 유도할 수 있고, 연구자가 노이즈 파라미터를 직접 통제하며 유용성-보안성 트레이드오프 곡선(Pareto Frontier)을 도출하기에 유리하다. 다만 노이즈 파라미터(ε)를 연구자가 직접 주입하는 합성 실험 설계라, 실제 사람·봇의 행동이 개입하는 살아있는 상호작용 데이터가 아니어서 본 연구가 다루고자 한 '실시간 행동 기반 이상 탐지'라는 관심 분야와 거리가 있다고 판단해 보류하였다.

최종 가설을 고른 이유: 위 세 후보는 모두 학술적 가치가 있었지만 공통적으로 연구자가 직접 원천 데이터를 생성·통제할 수 없는 외부 관찰 데이터(취약점 공시, 피싱 URL 수집, 합성 노이즈 주입)에 의존하였다. 반면 행동 기반 시계열 이상 탐지는 연구자 본인이 실제로 타이핑하고 클릭하여 원자료 생성부터 반증 가능한 가설 검증까지 전 과정을 직접 수행·확인할 수 있었던 유일한 주제였으므로 최종 채택하였다.

AI 와 가설을 다듬은 과정: 최초 구상은 '행동 로그로 봇을 구분할 수 있다'는 느슨한 아이디어였다. AI 도구에게 관련 선행 연구(키스트로크·마우스 다이나믹스, 타이밍 채널 탐지)를 탐색·요약하도록 맡긴 뒤, 그 결과를 참고해 연구자가 직접 '개인 내 분산 대 사용자 간 분산'이라는 반증 가능한 기준과 '시계열 자기상관성·엔트로피·마할라노비스 거리'라는 구체적 측정 방법을 추가해 현재의 한 문장 가설(1.2 절)로 좁혔다.

즉 AI 는 후보 탐색과 문헌 요약을 보조했고, 가설의 변수 정의와 기각 기준을 확정한 것은 연구자 본인의 판단이다.

1.4 선행 연구 검토 및 가설 뒷받침 근거

1. **키스트로크 다이나믹스와 통계적 거리 측정 — Killourhy & Maxion (2009):** 51 명의 타이핑 데이터(누름 시간, 키 간 이동 시간)를 수집하여 마할라노비스 거리, 맨해튼 거리, One-Class SVM 등 14 개 이상 탐지 알고리즘의 성능을 비교하고 다변량 공분산을 반영한 통계적 거리 지표의 우수성을 입증하였다. **이 연구는 내 가설의 "타건 간격의 다변량 분포가 개인 고유의 행동 지문을 형성하여 통계적 거리만으로 정상 사용자와 타인을 분리해낼 수 있다"는 부분을 뒷받침한다.**
2. **마우스 동역학 기반 지속적 인증 및 봇 탐지 — Ahmed & Traore (2007); Feher et al. (2012):** 단순 좌표가 아닌 마우스 이동 속도, 가속도, 각도, 곡률 등의 시계열 파생변수를 추출하여 로그인 이후 세션 중에도 계정 탈취자나 매크로 봇을 지속적으로 탐지하였다. **이 연구는 내 가설의 "마우스 가속도 및 궤적의 시계열적 리듬이 개인 내 분산을 줄이고 계정 탈취자 및 매크로 봇과의 사용자 간 분산을 유의미하게 벌려준다"는 부분을 뒷받침한다.**
3. **이벤트 발생 간격의 엔트로피와 자기상관성 분석 — Gianvecchio & Wang (2007); Chu et al. (2010):** 인간의 불규칙한 활동 간격(폭발성)과 자동화 봇의 주기적·인위적 난수 간격을 샤논 엔트로피, 조건부 엔트로피, 자기상관성 지표로 구분해냈다. **이 연구는 내 가설의 "단일 이벤트의 정적 기준만으로는 포착할 수 없는 지능형 매크로 봇을 이벤트 발생 간격의 자기상관성 및 엔트로피로 식별할 수 있다"는 부분을 뒷받침한다.**
4. **다변량 시계열 비지도 학습 기반 내부자 위협 탐지 — Tuor et al. (2017):** 정상 사용자의 다변량 활동 시계열 요약 통계량을 비지도 학습으로 모델링하여 사전 공격 라벨 없이도 비정상 접근의 이상 점수(Anomaly Score)를 산출하였다. **이 연구는 내 가설의 "사전 정의된 공격 데이터 없이 정상 사용자의 다변량 행동 분포 학습만으로도 비정상 접근의 유의미한 결정 경계를 형성할 수 있다"는 부분을 뒷받침한다.**

자동화 위협의 실무 분류체계 — OWASP (n.d.): 크리덴셜 스터핑(Credential Stuffing), 스캘핑(Scalping) 등 실제 웹 서비스에서 관찰되는 자동화 위협을 20 여 종으로 유형화하고, 그중 계정 탈취형 위협과 이미 인증된 접근을 남용하는 위협을 구분하였다. 이 분류는 내 가설이 다루는 두 응용 시나리오 — 운동 역학 변수 기반 계정 탈취 방어(1.5 절 1 번)와 시간 구조 변수 기반 매크로·부정 사용 방지(1.5 절 2 번) — 가 실제로 서로 다른 성격의 자동화 위협 범주에 대응한다는 배경을 뒷받침한다.

1.5 실전 활용 시나리오

본 연구의 핵심 발견 중 운동 역학 변수(등록 기반 '본인 대 타인' 식별)는 계정 탈취 방어라는 전통적 의미의 보안 문제에 직접 대응하고, 시간 구조 변수(등록 없는 '사람 대 기계' 식별)는 자동화 매크로·부정 사용 방지라는 인접 영역에 대응한다 — 기술적으로는 같은 다변량 거리 체계를 쓰지만, 다루는 위협의 성격은 다르다(계정 탈취는 무단 접근, 매크로·스캘핑은 이미 정당하게 인증된 접근의 불공정한 남용). 이 구분은 `인수인계서_보안_프레이밍_재검토.md`에서 자세히 다뤘다. 후속 구현(7 장)에서는 1 번(계정 탈취 방어)을 핵심 보안 기여로 삼아 주 기능으로 구현하고, 2 번(웹 폼 매크로 탐지)을 등록 없이 함께 제공되는 부가 기능으로 구현하였으며, 3 번(PC 자동 잠금)은 검토 후 기각하였다.

1. 계정 탈취(크리덴셜 스터핑) 방어 — 핵심 보안 기여, 주 기능: 로그인·회원 정보 폼에서 운동 역학 변수(타건 지연 분포·마우스 가속도 표준편차)로 본인의 입력 리듬을 등록해 두면, 비밀번호가 유출되어 정확히 입력되더라도 입력 리듬이 다른 제 3 자의 접속을 구분해 추가 인증을 요구할 수 있다. OWASP 가 Credential

Stuffing 으로 분류하는, 무단 접근을 막는 전통적 보안 문제에 직접 대응하는 응용이다.
2. 웹 폼 매크로 차단 — 부가 기능: 수강신청·티켓팅 매크로(OWASP Scalping), 가입·게시 자동화 같은 자동화 공격에 대해 시간 구조 변수(자기상관성·샤논 엔트로피)만으로 등록 없이 사람인지 기계인지 판정한다. 다만 이 영역은 이미 정당하게 인증된 계정의 '남용'을 막는 것이라, 엄밀히는 무단 접근을 막는 보안보다 부정 사용 방지(anti-fraud)·공정성 집행에 더 가깝다는 점을 분명히 해 둔다.
3. PC 자동 잠금 — 검토 후 기각: 자유 타이핑을 상시 감시해 계정 탈취자를 걸러내는 지속 인증 에이전트를 먼저 프로토타입으로 구현했으나(지속인증_PC 잠금_프로토타입/), 고정 과업 밖(자유 타이핑)에서는 4.4 절 한계 2 번을 그대로 어기고, 450 타 등록 후에도 held-out 정상 데이터 오탐이 40%에 달했으며(구 버전 8.3 절), 전역 키보드 후킹이라 키로거처럼 보이는 문제가 있어 응용 대상에서 제외하였다. 이 프로토타입의 코드와 실측 결과는 보존하되, 실전 응용으로는 채택하지 않는다.

---

2. 연구 방법 (Methods)

2.1 실험 설계 (독립변인, 통제변인, 종속변인)

결과를 유리하게 고르는 편향(Cherry-picking)을 방지하기 위해, 실험 시작 전 조작할 조건(독립변인), 고정할 조건(통제변인), 반복 횟수, 그리고 숫자로 기록할 측정 지표(종속변인)를 아래 표와 같이 사전 정의하였다.

구분	항목	상세 설정 내용
바꿀 조건 (독립변인)	행동 주체 (4 개 그룹)	**1) 정상 사용자 (User_A):** 연구자 본인의 평상시 입력 리듬 모사 **2) 타인 (Impostor_B):** 계정을 탈취한 타인을 모사한 다른 사용자의 입력 **3) 단순 매크로 봇 (Bot_Fixed):** 정상 사용자와 동일한 평균 속도(누름 90ms, 이동 140ms)이나 일정한 고정 주기로 동작하는 봇 **4) 지능형 매크로 봇 (Bot_Random):** 정적 탐지를 우회하기 위해 평균 속도와 산포도를 정상 사용자와 유사하게 맞추고 균등분포 난수(누름 70~110ms, 이동 70~210ms)를 주입한 봇
고정할 조건 (통제변인)	과업 및 실험 환경	- **동일 과업:** 1 회 세션당 지정된 30 타 분량의 타이핑 및 5 개 타겟 좌표 순서대로 마우스 클릭 - **동일 환경:** 동일한 PC 환경, 해상도(1920×1080), 동일한 파이썬

구분	항목	상세 설정 내용
		로깅 및 분석 파이프라인 - **단일 이벤트 총량 고정:** 1 회 시행당 총 키 입력 수(30 회) 및 마우스 이동 거리 총합을 동일하게 통제
반복 횟수 (표본 크기)	그룹당 15 회 (총 60 회)	- 우연에 의한 오차를 배제하기 위해 최소 기준(10 회)을 상회하는 **조건당 15 회 반복 실행 (총 60 개 세션 기록)** - 본 실험 전 1 회 파일럿 실행(Pilot Run)을 통해 누락 변수 및 기록 포맷 점검 완료
숫자로 기록할 것 (종속변인)	시계열 파생변수 (7 종) 및 다변량 이상 점수	1. dwell_mean_ms: 키 누름 지속 시간(Dwell Time) 평균 (ms) 2. dwell_std_ms: 키 누름 지속 시간 표준편차 (ms) 3. flight_mean_ms: 키 간 이동 시간(Flight Time) 평균 (ms) 4. flight_std_ms: 키 간 이동 시간 표준편차 (ms) 5. inter_event_autocorr: 연속 이벤트 간격의 1 차 자기상관계수 (Lag-1 Autocorrelation) 6. inter_event_entropy: 이벤트 간격 분포의 샤논 엔트로피 (Shannon Entropy, bits) 7. mouse_accel_std: 마우스 이동 가속도의 표준편차 (px/s²) 8. mahalanobis_dist: 정상 사용자(User_A) 다변량 분포 중심으로부터의 마할라노비스 거리

2.2 데이터 수집 및 이상 점수 산출 절차

각 세션(N=30 이벤트)에서 수집된 7 차원 시계열 파생변수 벡터에 대하여, 정상 사용자(User_A) 15 회 반복 데이터의 표본평균 벡터와 Ledoit-Wolf 축소(shrinkage) 공분산 행렬을 기준으로 다변량 마할라노비스 거리(mahalanobis_dist)를 산출하였다. 표본 공분산 대신 Ledoit-Wolf 를 쓴 이유는 15 개 표본으로 7 차원 공분산을 추정할 때 발생하는 불안정성(7.3 절 참고) 때문이며, 두 방법의 결과 차이는 P0_리포트.md 에 함께 기록하였다.

원시 타이밍부터 세션을 생성하고 특징·거리를 계산하는 전체 코드는 매크로탐지_위젯/core/simulate.py·features.py·covariance.py 와 research/generate_simulation.py 에 있으며(seed=42 고정), 모든 개별 시행의 측정치는 요약하지 않고 원자료 파일에 영구 보존하였다.

---

3. 연구 결과 (Results)

3.1 60 회 실험 원자료 요약 통계

4 개 조건별 15 회씩 총 60 회 시행 원자료(원자료_시계열_행동로그_실험결과_60 회.csv)에서 도출된 8 개 수치형 변수의 평균, 표준편차(SD), 중앙값, 최솟값 및 최댓값은 아래 표와 같다.

조건 (그룹, n=15)	dwell_mean_ms 평균±SD (최소~최대)	dwell_std_ms 평균±SD (최소~최대)	flight_mean_ms 평균±SD (최소~최대)	flight_std_ms 평균±SD (최소~최대)	inter_event_autocorr 평균±SD (최소~최대)	inter_event_entropy 평균±SD (최소~최대)	mouse_accel_std 평균±SD (최소~최대)	mahalanobis_dist 평균±SD [중앙값] (최소~최대)
정상 사용자 (User_A)	91.42±1.40 (88.89~93.37)	10.86±1.32 (8.29~14.02)	138.37±5.22 (130.27~147.13)	27.31±4.06 (22.16~37.81)	0.3058±0.1594 (0.0097~0.5987)	1.8077±0.1620 (1.5514~2.0777)	1443.99±123.21 (1165.80~1633.86)	0.97±0.61 [0.75] (0.34~2.52)
타인 (Impostor_B)	127.62±3.30 (122.73~133.69)	16.50±1.67 (13.26~18.97)	209.31±11.49 (188.77~231.15)	40.98±6.01 (27.93~48.49)	0.2877±0.1139 (0.1298~0.5238)	2.2533±0.2035 (1.8322~2.4871)	2140.54±168.37 (1908.82~2472.07)	7.66±1.16 [7.40] (6.10~10.18)
단순 봇 (Bot_Fixed)	90.05±0.14 (89.78~90.27)	0.77±0.10 (0.63~0.95)	139.63±1.38 (137.82~142.77)	0.50±0.21 (0.19~0.95)	0.8284±0.1421 (0.4691~0.9805)	0.0000±0.0000 (0.0000~0.0000)	14.97±0.77 (13.59~16.16)	13.02±0.01 [13.02] (13.00~13.03)
지능형 난수봇 (Bot_Random)	89.65±2.30 (86.36~92.89)	11.50±0.77 (9.80~12.67)	193.24±17.31 (156.49~213.44)	93.16±8.13 (76.82~105.68)	-0.1125±0.1677 (-0.4380~0.1771)	3.0511±0.1337 (2.7919~3.2332)	305.05±21.51 (257.45~341.47)	11.42±0.32 [11.46] (10.74~11.86)

[v2 정정] 위 표는 기존 원자료(원자료_시계열_행동로그_실험결과_60 회.csv)를 대체한다. 원자료 재생성 과정에서 (1) 기존 CSV 를 만든 실행 가능한 생성 코드가 패키지에 없었고, (2) 본문 2.2 절이 기술한 '표본 공분산' 방법으로 기존 CSV 를 재계산하면 보고된 거리(예: Impostor_B 7.64~10.21)가 아니라 수백 단위(611~833)가 나와 원 수치의 산출 방법을 특정할 수 없음을 확인하였다. 이에 raw 타이밍부터 60 세션을 다시 생성하고(seed=42, core/simulate.py), Ledoit-Wolf 축소 공분산으로 거리를 다시 계산하였다(연구자 확인 완료, 2026-10-26). Bot_Random 의 flight 분포는 엔트로피 목표(3.29 bits) 재현을 위해 U(70,210)에서

U(20,350)으로 넓혔으며, 그 결과 flight_mean_ms 가 140ms 대에서 193ms 대로 바뀌었다 — '평균 속도 위장'이라는 원래 설계 의도와는 멀어지지만, 매크로 탐지 자체는 시간 구조 변수(자기상관·엔트로피)만 쓰므로 핵심 결론에는 영향이 없다. 전 과정과 수치 비교표는 매크로탐지_위젯/research/P0_리포트.md 에 전량 공개하였으며, 이하 3.2·3.3·4.3 절의 수치는 모두 이 재생성 결과를 따른다. 재현성을 위해 trial 단위 인용은 생략하고 구간(최소~최대)과 평균만 인용한다 — 전 시행 값은 CSV 에 그대로 남아 있다.

3.2 가설대로 나온 부분 (원자료 수치 근거)

1. 단일 정적 기준(평균 속도)의 탐지 실패 입증: 키 간 이동 시간 평균(flight_mean_ms)에서 정상 사용자 User_A 의 분포는 130.27~147.13ms(평균 138.37ms)였다. 단순 봇 Bot_Fixed(137.82~142.77ms)의 전 시행 측정치는 User_A 의 범위 내부에 완전히 포함되어, 정적 평균 기준만으로는 Bot_Fixed 를 식별할 수 없었다. 키 누름 시간 평균(dwell_mean_ms) 역시 User_A(88.89~93.37ms) 범위에 Bot_Fixed(89.78~90.27ms)가 완전히, Bot_Random(86.36~92.89ms)이 대부분 겹쳤다. 다만 Bot_Random 의 flight_mean_ms 는 156.49~213.44ms 로 User_A 범위와 전혀 겹치지 않았는데, 이는 엔트로피 재현을 위해 flight 분포를 넓힌 데 따른 부작용이다(v2 정정 참고) — 즉 재생성된 Bot_Random 은 더 이상 평균 속도를 위장하지 못하지만, 매크로 탐지 로직 자체는 평균 속도를 쓰지 않으므로 핵심 논지(정적 평균 기준의 무력함)는 Bot_Fixed 사례만으로도 유지된다.
2. 시간 구조 변수(자기상관성·엔트로피)를 통한 자동화 봇 식별: 샤논 엔트로피(inter_event_entropy)는 User_A(1.5514~2.0777 bits)와 Bot_Fixed(0.0000 bits 고정), Bot_Random(2.7919~3.2332 bits) 사이에 겹침이 전혀 없어 가장 안정적인 '사람 대 기계' 판별 변수로 확인되었다. 반면 1 차 자기상관계수(inter_event_autocorr)는 단독으로는 완전히 분리되지 않았다 — User_A(0.0097~0.5987)와 Bot_Fixed(0.4691~0.9805) 사이, User_A 와 Bot_Random(-0.4380~0.1771) 사이 모두 일부 구간이 겹쳤다. 이는 자기상관계수를 29 개 표본만으로 추정할 때 생기는 소표본 추정 편향 때문으로(P0_리포트.md 5 번 참고), 1 차 연구가 보고한 것보다 자기상관 단독의 분리력이 약하다는 점을 이번 재생성에서 추가로 확인하였다. 그럼에도 엔트로피가 확실히 분리해 주므로, 두 변수를 함께 쓰는 시간 구조 벡터(2 차원)는 여전히 사람과 기계를 안정적으로 가른다.
3. 다변량 마할라노비스 거리를 통한 완벽한 분리 경계 형성: 7 종 파생변수와 User_A 기준 Ledoit-Wolf 공분산으로 산출한 mahalanobis_dist 에서 User_A 의 개인 내 분포는 0.34~2.52(평균 0.97)의 좁은 영역에 수렴하였다. 반면 Impostor_B 는 6.10~10.18(평균 7.66), Bot_Random 은 10.74~11.86(평균 11.42), Bot_Fixed 는 13.00~13.03(평균 13.02)을 기록하여, 정상 최댓값(2.52)과 비정상 최솟값(6.10) 사이에 3.58 이상의 안전 마진이 확보되었다(60 회 전 시행 겹침 0 건).

3.3 가설과 다르게 나온 부분 (전수 기록)

초기 가설에서는 모든 시계열 리듬 변수가 개인 고유 지문으로 작동할 것이라 예상했으나, 원자료 확인 결과 개별 변수 차원에서는 다음 세 가지 중첩 현상이 나타났다.

1. User_A 와 Impostor_B 간의 1 차 자기상관계수(inter_event_autocorr) 중첩: User_A 의 범위(0.0097~0.5987)와 Impostor_B 의 범위(0.1298~0.5238)가 큰 폭으로 겹쳤다. 자기상관계수 단독으로는 사람과 사람을 구분할 수 없다는 결론은 1 차 연구와 동일하게 유지되었다.
2. User_A 와 Impostor_B 간의 샤논 엔트로피(inter_event_entropy) 중첩: User_A(1.5514~2.0777 bits)와 Impostor_B(1.8322~2.4871 bits)의 범위가 1.8322~2.0777 구간에서 실질적으로 겹쳤다. 1 차 연구에서는 두 그룹의 간격이 0.0060 bits 로 '근접'하는 수준이었으나, 재생성 결과에서는 겹침이 더 뚜렷하게 나타났다 — 엔트로피 역시 '사람 대 기계'는 가르지만 '사람 대 사람'은 가르지 못한다는 가설(4.1 절 [가능성 1])과 더 명확히 부합하는 방향이다.

3. User_A 와 Bot_Random 간의 누름 시간 표준편차(dwell_std_ms) 교란: dwell_std_ms 에서 Bot_Random 의 범위(9.80~12.67ms)가 User_A 의 범위(8.29~14.02ms) 내부에 완전히 포함되어, 1 차 연구와 동일하게 단순 표준편차만으로는 사람과 균등분포 난수 봇을 구분할 수 없었다. 다만 flight_std_ms 는 Bot_Random 을 엔트로피 목표에 맞춰 재설정하면서 76.82~105.68ms 로 크게 벌어져, User_A(22.16~37.81ms)·Impostor_B(27.93~48.49ms)와 더 이상 겹치지 않게 되었다 — 1 차 연구가 보고한 'flight_std_ms 로도 사람 타인과 난수 봇을 구분할 수 없다'는 관찰은 재생성된 Bot_Random 에는 더 이상 적용되지 않는다(P0_리포트.md 4 번 참고).

---

4. 논의 (Discussion)

4.1 가설과 다르게 나온 이유에 대한 3 가지 가능성 검토 및 검증

1. **[가능성 1] 자기상관성과 엔트로피는 '개인 고유 특성'이 아니라 '인간 타이핑 메커니즘의 종(Species) 공통 특성'일 가능성:** 실험 구조와 원자료를 대조한 결과, 연속 타이핑 시 앞선 타건이 다음 타건에 영향을 주는 신경·근육학적 관성(컨볼루션 가중치 [0.7, 0.3] vs [0.65, 0.35])은 사람이라면 누구나 유사하게 작용한다. 따라서 자기상관성(0.31~0.45)과 엔트로피(2.60~2.90 bits)는 '인간 대 기계(봇)'를 가르는 지표일 뿐, '사람 A 와 사람 B'를 가르는 개인 지문 역할은 하지 못함이 확인되었다.
2. **[가능성 2] 균등분포 난수(Uniform(70, 110))의 이론적 표준편차가 정상 사용자의 타건 표준편차와 일치했을 가능성:** 연속균등분포 U(a, b)의 표준편차 공식 (b-a)/√12 에 Bot_Random 의 설정값(70~110ms)을 대입하면 이론적 표준편차는 40/√12 ≈ 11.55ms 가 된다. 이는 User_A 의 실제 누름 시간 표준편차(평균 10.86ms, 범위 9.65~12.10ms)와 정확히 겹치며, 공격자가 난수 폭만 조절하면 1 차 산포도(std)는 얼마든지 위장할 수 있음이 수리적으로 입증되었다.
3. **[가능성 3] 1 회 세션당 표본 크기(N=30) 제약으로 인한 히스토그램 엔트로피 추정 분산 증가:** 30 타라는 비교적 짧은 시퀀스를 10 개 구간(bins)으로 나누어 엔트로피를 추정하다 보니 표본 변동성이 발생하여 User_A 상한(2.7680)과 Impostor_B 하한(2.7740)이 0.0060 bits 차이로 근접하게 되었다.

4.2 데이터에 맞춘 가설 수정 (수정 전 vs 수정 후)

원자료 분석에서 드러난 변수별 상보적 역할 분담을 반영하여 가설을 다음과 같이 수정하였다.

- **고치기 전 가설 (초기 가설):**
  "사용자의 입력 및 활동 로그에서 추출한 시계열적 리듬(타건 간격, 마우스 가속도, 이벤트 발생 간격의 자기상관성 및 엔트로피 등)의 다변량 분포는 개인 고유한 '행동 지문(Behavioral Fingerprint)'을 형성하므로, 단일 이벤트의 정적 기준만으로는 포착할 수 없는 계정 탈취자나 자동화 매크로 봇의 비정상 접근을 통계적으로 유의미하게 분리해낼 수 있다."
- **고친 후 가설 (데이터 기반 수정 가설):**
  "단일 정적 지표(평균 속도)나 개별 산포도만으로는 평균과 분산을 위장한 지능형 난수 봇(Bot_Random) 및 타인(Impostor_B)을 온전히 분리할 수 없으나, **기계적 주기성과 무작위성을 포착하는 '시간 구조 변수(1 차 자기상관성·샤논 엔트로피)'**와 **개인별 신체 운동 특성을 반영하는 '운동 역학 변수(타건 지연 시간 분포·마우스 가속도 표준편차)'**를 **다변량 마할라노비스 거리로 결합**하면, 각 변수의 개별 중첩 한계를 상호 보완하여 계정 탈취자와 자동화 매크로 봇을 모두 정상 사용자로부터 분리해낼 수 있다."

4.3 최종 결론

본 연구는 4 개 행동 주체(User_A, Impostor_B, Bot_Fixed, Bot_Random)에 대해 각 15 회씩 총 60 회의 반복 실험을 수행하고(0 장 P0 에서 raw 타이밍부터 재생성, seed=42) 7 종의 시계열 파생변수 원자료를 분석하여 행동 기반 이상 탐지의 작동 메커니즘을 규명하였다. 분석 결과, 키 간 이동 시간 평균이나 키 누름 표준편차 같은 개별 통계량, 그리고 1 차 자기상관계수 단독으로는 정상 사용자와 봇·타인의 분포가 상당 부분 겹쳐 단독 기준으로는 안정적인 탐지가 불가능했다(3.2·3.3 절). 그러나 '인간과 기계의 시간적 규칙성 차이'를 잡아내는 자기상관성·엔트로피 변수와 '개인 간 운동 신경 차이'를 잡아내는 타건 속도·마우스 가속도 변수를 결합하여 Ledoit-Wolf 공분산 기반 다변량 마할라노비스 거리를 산출했을 때, 정상 사용자는 0.34~2.52(평균 0.97) 구간에 밀집한 반면 타인(6.10~10.18), 지능형 난수 봇(10.74~11.86), 단순 봇(13.00~13.03)은 최소 6.10 이상으로 크게 벌어지며 60 회 전 시행에서 겹침 없이 분리되었다(안전 마진 3.58 이상). 결론적으로 행동 기반 보안 탐지의 핵심은 개별 변수의 단독 임계값이 아니라, 서로 다른 침입 유형(타인 vs 봇)에 반응하는 상보적 시계열 변수들의 다변량 결합에 있음이 원자료로 입증되었다. 이 결론의 방향은 최초 보고 수치(안전 마진 4.70)와 재생성 수치(안전 마진 3.58) 모두에서 동일하게 유지된다 — 다만 구체적 수치는 0 장 P0 에서 확인한 산출 방법 불일치로 인해 v2 에서 갱신되었다(7.3 절·P0_리포트.md).

4.4 연구의 한계 (이 연구로 말할 수 없는 것)

1. **시뮬레이션 데이터 기반 실험의 한계:** 본 실험의 60 회 원자료는 확률 분포(정규분포, 감마분포, 컨볼루션, 균등분포)를 통제하여 생성한 시뮬레이션 결과이므로, 실제 수십 명의 인간 피험자가 피로도, 감정 상태, 시간대 변화에 따라 겪는 생체적 '개인 내 분산(Intra-user variance)'의 일간·주간 변동을 대변할 수 없다.
2. **과업 및 환경의 단일성 한계:** 30 타 분량의 고정 텍스트 입력과 지정된 5 개 타겟 클릭이라는 단일 통제 조건에서만 실험했기 때문에, 자유로운 웹 서핑이나 코딩, 게임 등 비정형 작업 환경에서도 동일한 마할라노비스 거리 임계값이 유지된다고 주장할 수 없다.
3. **고도화된 인간 모방형 생성 AI 봇에 대한 검증 부재:** 본 실험의 지능형 봇(Bot_Random)은 독립 균등분포 난수를 사용했기 때문에 자기상관계수가 0.0016 근처로 떨어져 쉽게 탐지되었다. 만약 공격자가 실제 인간의 시계열 자기상관 구조와 마우스 가감속 곡선까지 모방하는 생성형 AI 봇(GAN 등)을 사용할 경우에도 본 모델이 유효한지는 이 연구의 데이터만으로 말할 수 없다.
4. **표본 크기 및 타인 그룹 수의 제약:** 조건당 15 회(총 60 회) 반복과 정상 1 명 대 타인 1 명(Impostor_B) 구조로만 실험했으므로, 본 연구의 정상 사용자와 우연히 평균 타건 속도가 비슷한 또 다른 타인(Impostor_C, D 등)이 등장했을 때의 실제 오탐률(FPR)과 미탐률(FNR)을 일반화할 수 없다.

---

5. 참고문헌 (References)

참고문헌은 APA(American Psychological Association) 제 7 판 양식으로 통일하여 기술하였다.

- Ahmed, A. A. E., & Traore, I. (2007). A new biometric technology based on mouse dynamics. *IEEE Transactions on Dependable and Secure Computing*, 4(3), 165–179.
- Chu, Z., Gianvecchio, S., Wang, H., & Jajodia, S. (2010). Who is tweeting on Twitter: Human, bot, or cyborg? In *Proceedings of the 26th Annual Computer Security Applications Conference (ACSAC)* (pp. 21–30). ACM.
- Feher, C., Elovici, Y., Moskovitch, R., Rokach, L., & Schclar, A. (2012). User identity verification via mouse dynamics. *Information Sciences*, 201, 19–36.

- Gianvecchio, S., & Wang, H. (2007). Detecting covert timing channels: An entropy-based approach. In *Proceedings of the 14th ACM Conference on Computer and Communications Security (CCS)* (pp. 307–316). ACM.
- Killourhy, K. S., & Maxion, R. A. (2009). Comparing anomaly-detection algorithms for keystroke dynamics. In *Proceedings of the 2009 IEEE/IFIP International Conference on Dependable Systems & Networks (DSN)* (pp. 125–134). IEEE.

OWASP Foundation. (n.d.). OWASP Automated Threats to Web Applications. Retrieved October 26, 2026, from https://owasp.org/www-project-automated-threats-to-web-applications/

- Tuor, A., Kaplan, S., Hutchinson, B., Nichols, N., & Robinson, S. (2017). Deep learning for unsupervised insider threat detection in structured cybersecurity data streams. In *Workshops at the Thirty-First AAAI Conference on Artificial Intelligence* (pp. 224–231). AAAI Press.

제외한 문헌 및 사유: 검색 과정에서 발견된 키스트로크·마우스 다이나믹스 관련 상업 솔루션 소개 자료 및 블로그 게시물 다수는 저자·발표 연도·재현 가능한 방법론이 명시되지 않아 1 차 출처로 보기 어려워 제외하였다. 또한 얼굴·음성 등 비시계열 생체인식 전반을 다루는 리뷰 논문들은 본 가설이 다루는 '타건·마우스 이벤트의 시계열 리듬'과 측정 대상이 직접 겹치지 않아 제외하였다. OWASP 관련 자료 중 위키 아카이브(wiki.owasp.org) 페이지와 제 3 자 요약 페이지(F5 Glossary 등)는 공식 1 차 출처가 아니므로 인용하지 않고, owasp.org 의 공식 프로젝트 페이지만 인용하였다.

출처 확인 방법: 학술 논문은 저자명과 발표 연도로 검색하여 논문이 실린 학술지·컨퍼런스 명과 DOI 또는 공식 출판사 페이지(IEEE Xplore, ACM Digital Library, ScienceDirect, AAAI Press 등)가 서로 일치하는지 대조하였다. OWASP 문헌은 웹 검색으로 owasp.org 의 공식 프로젝트 페이지(owasp.org/www-project-automated-threats-to-web-applications/)에 직접 접속하여 제목과 발행 주체(OWASP Foundation)를 확인하였다.

---

6. 재현 방법 (Reproducibility Guide)

다른 연구자가 동일한 원자료와 분석 결과를 그대로 재현할 수 있도록 패키지 구성과 실행 절차를 다음과 같이 제공한다.

6.1 재현 패키지 폴더 및 파일 구성 (행동_기반_이상_탐지_연구_재현_패키지.zip)

- **완성논문_시계열_문맥을_반영한_행동_기반_이상_탐지_최재영.docx / .md:** 표지, 초록, 본문(서론·방법·결과·논의), 참고문헌, 재현 방법, 역할 구분이 포함된 완성 논문 파일
- **data/원자료_시계열_행동로그_실험결과_60 회.csv:** 4 개 조건 × 15 회 반복 실행(총 60 회) 전체 원자료 데이터셋
- scripts/run_experiment.py: 저장된 CSV 원자료를 불러와 조건별 평균 지표를 출력하는 로드 확인 스크립트 — 주의: 60 세션을 새로 실행·생성하지 않는다(과거 버전이 이렇게 오인되던 것 자체가 0 장 P0 가 다룬 재현성 문제였다). raw 타이밍부터 60 세션을 실제로 생성하는 코드는 매크로탐지_위젯/core/simulate.py·research/generate_simulation.py 에 있다(6.3 절).
- **scripts/analyze_and_plot.py:** 원자료 CSV 를 읽어 조건별 기초 통계량 요약표를 출력하고 4 분할 분포 비교 박스플롯(figures/experiment_results_summary.png)을 생성하는 분석 스크립트
- **figures/experiment_results_summary.png:** 조건별 주요 지표 분포 비교 시각화 그래프
- **README_재현절차.md:** 실행 환경 및 단계별 재현 명령어 안내서

6.2 단계별 실행 명령어

Python 3.8 이상 환경(필수 패키지: pandas, matplotlib, seaborn)에서 압축을 해제한 뒤 아래 두 명령어를 순서대로 실행하면 저장된 원자료로부터 동일한 통계표와 그래프가 즉시 재현된다. 원자료 자체를 raw 타이밍부터 재생성하려면 6.3 절의 매크로탐지_위젯 절차를 따른다.

1. 원자료 로드 확인: python scripts/run_experiment.py
2. **통계 요약표 출력 및 그래프 생성:** python scripts/analyze_and_plot.py

6.3 0 장 P0 재생성 절차 (v2)

매크로탐지_위젯/ 폴더(별도 하위 프로젝트)에서 아래를 순서대로 실행하면 3.1 절 표가 그대로 재현된다.
1 단계: pip install -r requirements.txt
2 단계: python research/generate_simulation.py — raw 타이밍부터 60 세션을 생성하고(seed=42), Ledoit-Wolf·표본 공분산 두 방법의 마할라노비스 거리를 모두 계산해 비교 리포트를 출력한다. 기존 원자료는 research/legacy/에 보존된다.
3 단계: python -m pytest tests/ — 단위·분리 검증 테스트 37 개 실행
자세한 비교표와 연구자 결정 사항은 매크로탐지_위젯/research/P0_리포트.md 에 전량 공개하였다.

---

7. 후속 구현: 매크로 탐지 위젯

7.1 응용 설계: PC 잠금에서 계정 보호(+매크로 탐지)로 전환한 이유

본 연구가 처음 제안한 실전 응용은 PC 자동 잠금 에이전트였다(1.5 절 3 번). 이를 코드 수준으로 구현하여(지속인증_PC 잠금_프로토타입/, pynput 기반 학습 모드·보안 모드) 연구자 본인의 실시간 타이핑·마우스 데이터로 예비 검증한 결과, 두 가지 핵심 발견이 나왔다.
소량 표본에서의 공분산 과적합 재현 (구 버전 8.3 절 흡수): 학습 윈도우 15 개로 프로필을 만들면 held-out 정상 데이터 10 건 중 4 건(40%)이 오탐으로 분류되었다. 당시 프로토타입은 특징을 6 차원(flight_std_ms 누락)만 썼는데도 이 정도였으므로, 본 연구의 7 차원 기준으로는 표본 부족 문제가 더 클 수 있다. 이는 4.4 절 '표본 크기 및 타인 그룹 수의 제약' 한계가 통제된 시뮬레이션 밖의 소규모 실데이터 조건에서도 그대로 재현됨을 보여준 실증 사례였다.
작업 전환에 따른 이상치 유입 (구 버전 8.4 절 흡수): 실제 학습 데이터 수집 중 타이핑 도중 다른 창으로 전환하거나 키를 길게 누른 구간에서 dwell_mean_ms 가 1069ms·1604ms 까지 치솟는 이상치가 관측되었다 — 시뮬레이션에서는 가정하지 않았던, 실데이터 특유의 전처리 요구였다.
여기에 더해 자유 타이핑을 상시 감시하는 구조는 4.4 절 한계 2 번(고정 과업 밖 일반화 불가)을 정면으로 어겼고, 전역 키보드 후킹은 백신·EDR 에 키로거로 오인될 소지가 있었다. 이 네 가지 근거로 PC 잠금을 실전 응용에서 기각하고, 본 연구가 가장 강하게 입증한 '운동 역학 변수를 통한 본인-타인 분리'를 계정 탈취 방어라는 핵심 보안 기여로 삼고, 등록 없이 바로 쓸 수 있는 '시간 구조 변수를 통한 사람-기계 분리'(매크로 탐지)를 부가 기능으로 묶은 행동 기반 계정 보호 위젯으로 전환하였다(1.5 절). 두 핵심 발견은 설계에 직접 반영되었다: 등록이 필요한 기능(타인 탐지)은 최소 20 세션을 요구하도록 하여 과적합 문제에 대응했고(발견 1), 세션 품질 검사로 포커스 이탈·타이밍 이상치가 섞인 세션을 기준 계산·등록에서 자동 제외하도록 했다(발견 2).

7.2 구현: 등록 기반 타인 탐지(주 기능)와 등록 없는 매크로 탐지(부가 기능)의 분리

매크로탐지_위젯/core/features.py 는 본 연구의 7 종 파생변수 정의를 그대로 재사용하되, 샤논 엔트로피 구간을 재현 패키지의 (20, 350)ms·10 구간으로 고정하고 범위 밖 값은 버리지 않고 양 끝으로 clip 하도록 정했다. 판정은 두 단계로 나뉜다. (1) 타인 탐지(등록 필요, 주 기능)는 운동 역학 변수를 포함한 7 차원 전체로, 최소 20 세션(7.1 절 발견 1 에 따른 하한) 등록 후 Ledoit-Wolf 공분산 기반 거리로 본인 대 타인을 판정한다 — 계정 탈취 방어라는 핵심 보안 기여에 해당한다. (2) 매크로 탐지(등록 불필요, 부가 기능)는 시간 구조 변수 2 개(자기상관성·엔트로피)만으로 '사람 대 기계'를 가른다 — 4.1 절 [가능성 1]이 밝힌 '이 두 변수는 개인 지문이 아니라 사람 대 기계를 가르는 종 공통 지표'라는 발견을 그대로 응용 설계의 근거로 삼았다. 기준 분포는 1 단계(초기값)로 본 연구의 시뮬레이션 User_A+Impostor_B 30 세션에서, 2 단계(재보정)로 실데이터 50 세션·5 명 이상이 모이면 research/calibrate.py 로 교체되며, 어느 쪽을 썼는지는 결과 화면과 로그에 항상 표시한다. 두 거리(시간 구조·운동 역학) 모두 leave-one-out 99 백분위수를 임계값으로 쓰며, 참고용으로 카이제곱 분포 기준값(자유도 2, 99% ≈ 3.03)도 로그에 함께 남긴다. 판정 결과 화면은 두 거리를 막대로, 변수별 표준화 편차를 표로 보여주어(인수인계서 6.3 절) 매크로 의심/본인/타인 의심/사람(등록 없음) 중 어느 경로로 그 판정에 이르렀는지 설명한다. 백엔드(FastAPI+SQLite)와 분석 스크립트가 core/features.py 하나만 계산 출처로 공유하므로, '실험에 쓴 계산과 서비스의 계산이 같은 코드'임을 코드 구조로 보장한다.

7.3 실데이터 검증 결과

이 개정 시점까지는 실제 다수 참여자 데이터를 아직 수집하지 못했다 — research/analyze_real.py 를 실행하면 표 1(그룹별 특징 비교)은 출력되지만 표 2(매크로 탐지 혼동행렬)·표 3(타인 탐지 결과)은 데이터 부족으로 집계되지 않는다. 대신 판정 로직 자체는 시뮬레이션 기반 분리 테스트(core/detector.py 에 대한 pytest, 사람 세션 중 80% 이상이 매크로로 오탐되지 않고, 봇 세션 중 80% 이상이 매크로로 잡히는지 확인)와 서버 통합 테스트(FastAPI TestClient), 그리고 브라우저 자동화로 동의→타이핑→클릭→제출→판정→결과 화면까지 1 회 end-to-end 동작을 확인하는 것으로 검증 범위를 한정하였다(총 37 개 테스트 통과). 실제 여러 사람·여러 참여자 간의 FPR/FNR 은 연구자가 지인 5~10 명의 데이터를 모은 뒤 research/analyze_real.py 로 직접 확인해야 한다 — 연구자 확인 필요.

7.4 실제 매크로(AutoHotkey) 검증 결과

scripts/macro_ahk/fixed_macro.ahk·random_macro.ahk 를 작성하여, 본 연구의 시뮬레이션에서만 다루던 Bot_Fixed·Bot_Random 을 OS 수준의 실제 매크로로 재현할 수 있게 하였다. AutoHotkey 로 보낸 입력은 브라우저에 isTrusted=true 로 들어오므로, 단순히 isTrusted 플래그로는 이 매크로를 구분할 수 없고 본 연구가 검증한 시간 구조 기반 판별이 실제로 필요한 사례가 된다. 다만 이 스크립트는 AutoHotkey 가 설치된 실제 데스크톱에서 연구자 본인의 로컬 데모 페이지를 대상으로 직접 실행해야 확인할 수 있어, 이 세션에서는 실행 결과를 검증하지 못했다. (보안 소프트웨어 경고로 AutoHotkey 설치를 보류해 본 절 검증을 수행하지 못함)

7.5 새로 확인된 한계

엔트로피 고정 구간의 수학적 제약: Bot_Random 의 flight 를 원래 설계(U(70,210))대로 두면, 고정 엔트로피 구간(20,350)·10 구간 중 데이터가 걸치는 구간이 5~6 개뿐이라 엔트로피 상한이 log2(5)≈2.32bits 로 묶여, 1 차

연구가 보고한 3.2899bits(10 구간 이론 최댓값 3.3219 에 근접)는 이 설정으로는 애초에 도달할 수 없었다(0 장 P0). v2 는 flight 분포를 U(20,350)으로 넓혀 이 값에 다시 근접시켰지만, 그 대가로 Bot_Random 이 더 이상 평균 속도를 위장하지 못하게 되었다(3.2 절) — 엔트로피 충실도와 '평균 위장'이라는 설계 의도는 고정 구간 안에서 동시에 만족시킬 수 없는 트레이드오프였다.

소표본 자기상관 추정 편향: Bot_Fixed 의 자기상관을 AR(1) 위상 0.98 로 설계해도, 29 개 표본만으로 추정한 평균 자기상관은 0.83 에 그쳤다(3.1 절 표). 알려진 소표본 편향식(phi − (1+3phi)/n)으로 역산하면, n=29 에서는 어떤 phi<1 을 쓰더라도 기대 추정치가 약 0.86 을 넘을 수 없다 — 1 차 연구가 보고한 0.9809(표준편차 0.004 에 불과한 매우 좁은 분포)는 확률적 AR 과정보다 거의 결정론적인 생성 방식에서 나왔을 가능성을 시사한다.

실제 공격 150 세션(L0~L4, Playwright·Chromium, 각 30 세션) 실행 결과: 기존 클라이언트 측 검사(B1~B4 결합, ANY-B)는 흔적 숨김 설정(--disable-blink-features=AutomationControlled) 하나로 L1 부터 완전히 무력화되었다(탐지율 0%). 본 연구(T)는 L0·L1(고정 패턴)을 100% 잡았으나, 독립 난수로 속도만 위장한 L2(42.4%)·L3(45.5%)는 절반도 못 잡았고, 자기상관까지 흉내 낸 적응형 공격자 L4 는 9.1%만 잡았다. 이는 L0~L3 이 모두 잡힐 것이라는 당초 예상과 다른 결과다 — 원인은 attacks/timing.py 의 L2 가 논문 원래 설계(U(70,210))를 썼는데, 이 범위는 고정 엔트로피 구간(20,350)에서 최대 log2(5)≈2.32bits 까지만 가능해(위 문단) 사람 범위와 실질적으로 겹치기 때문이다. 즉 3.1 절 표가 보여준 '완벽한 분리'는 엔트로피 재현을 위해 범위를 넓힌(U(20,350)) 특정 Bot_Random 설정에서 나온 것이며, 공격자가 더 자연스러운 범위의 난수를 쓰면 본 연구의 탐지력도 크게 떨어진다는 것이 실측으로 확인되었다.

등록 기반 본인 오탐률 실측: 연구자 본인이 20 세션으로 등록한 뒤, 등록에 쓰지 않은 held-out 세션 10 건(참여자 n=1)을 평가한 결과 50%(5/10)만 '본인'으로 정확히 판정되었고, 30%(3/10)는 '다른 사람'으로, 20%(2/10)는 '매크로'로 오판되었다. 이는 구 버전 PC 잠금 프로토타입(7.1 절)에서 학습 15 세션으로 오탐 40%가 났던 것과 같은 성격의 문제 — 특징 차원 수(7 차원)에 비해 등록 세션(20 개)이 여전히 부족해 leave-one-out 99 백분위수 임계값 자체가 불안정하다는 것 — 이 이번에는 시뮬레이션이 아니라 실제 연구자 본인의 데이터로 재현된 것이다. 등록 세션을 늘리면(30~50 개) 개선될 가능성이 있으나 이번 연구에서는 검증하지 못했다.

등록 방식의 실사용 가능성 문제: 지금 설계는 본인 확인 기능을 쓰려면 동일 문장을 20 회(약 600 타) 반복 입력해야 등록이 끝난다. 이는 연구에 필요한 통계적 표본 수를 맞추기 위한 설계이지, 실제 서비스에 맞는 온보딩이 아니다. 실서비스라면 전용 등록 화면 없이, 평소 로그인 시의 비밀번호 입력 같은 자연스러운 상호작용에서 데이터를 조용히 축적하다가(관찰 모드) 표본이 충분해지면 자동으로 본인 확인 기능을 켜는 구조가 필요하다 — 이번 연구에서는 이 설계 방향만 식별했고 구현하지는 않았다.

실측 과정에서 발견한 구현 결함: (1) 빠르게 타이핑할 때(키 겹쳐 누르기, rollover) 마지막 1~2 타의 keyup 이벤트가 화면 전환 시점과 겹쳐 기록에서 누락되는 경쟁 조건이 있었다 — 수정 후 재현 테스트로 확인했다(그 뒤로도 1 건은 재발해 완전히 해결됐다고 단정하지 않는다). (2) 품질 기준의 백스페이스 허용치(최초 5 회)가 실제 타이핑에서는 대부분 초과되어 실측 후 10 회로 완화했다. (3) 참여자 식별자가 브라우저에만 저장돼 있어, 저장소가 사라지면(새로고침·사생활 보호 모드 등) 등록된 프로필과 무관한 새 참여자로 조용히 전환되는 문제가 있었다 — 실제로 held-out 평가용 세션 5 건이 이 문제로 엉뚱한 참여자에게 저장되어 폐기해야 했다. 참여자 ID 로 직접 재접속하는 기능을 추가해 완화했다.

평가 범위의 한계: B4(정적 속도 임계값)는 사람 기준 데이터가 모일 때까지 계산되지 않아(표 A 전부 '데이터 없음') 150 세션 비교에서 사실상 평가되지 못했다. L5(사람 타이밍 재생)와 AutoHotkey 실제 매크로 2 종은 각각 사람 데이터와 연구자의 직접 실행이 필요해 이번에도 실행하지 못했다. 사람 참여자가 1 명뿐이라 표 B(사람 오탐률)는 참여자 단위 leave-one-participant-out 분리를 적용할 수 없었고, 결과(n=10)는 일반화할 수 없다.